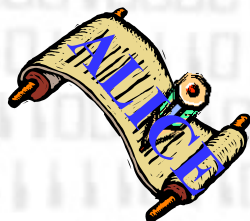


La signature



Un protocole de signature doit permettre :

- d'identifier l'expéditeur du message
- de contrôler l'intégrité du message
- d'assurer la non répudiation

La confidentialité ne fait pas partie des propriétés assurées par la signature.

Cadre formel

Un schéma de signature est un tuple (P, A, K, K', S, V) où :

- P est l'ensemble des messages à signer
- A est l'ensemble des signatures
- K est l'ensemble des clés de signature
- K' est l'ensemble des clés de vérification
- Pour chaque couple (k, k') , il existe une fonction de signature $\text{sig} \in S$ et une fonction de vérification $\text{ver} \in V$ telles que :

$$\begin{aligned}\text{sig} &: P \times K \rightarrow A \\ \text{ver} &: P \times A \times K' \rightarrow \{\text{vrai}, \text{faux}\}\end{aligned}$$

$$\forall x \in P, \forall y \in A, \quad \text{ver}(x, y, k') = \begin{cases} \text{vrai} & \text{si } y = \text{sig}(x, k), \\ \text{faux} & \text{sinon.} \end{cases}$$

- Le calcul de $\text{sig}(m,k)$ doit être polynomial en temps
- Le calcul de $\text{ver}(m,y,k')$ doit être polynomial en temps
- Les ensembles S, V et K' sont publics

Pour un couple (m,k') fixé, un intrus peut énumérer toutes les signatures possibles, jusqu'à trouver un s tel que $\text{ver}(m,s,k') = \text{VRAI}$

Il n'existe pas de schéma de signature inconditionnellement sûr.

- Il doit être « calculatoirement impossible » de produire une signature valide pour un couple (m,k') fixé.

➤ Modèles d'attaque :

- Attaque sans message (key only attack) : seule la fonction de vérification est connue
- Attaque à message(s) connu(s) : l'attaquant dispose d'une liste (m_i, s_i) .
- Attaque à message(s) choisi(s) : l'attaquant choisit une liste de messages $(m_i)_{i=1..n}$ et obtient les signatures correspondantes.

➤ Objectifs de l'attaquant :

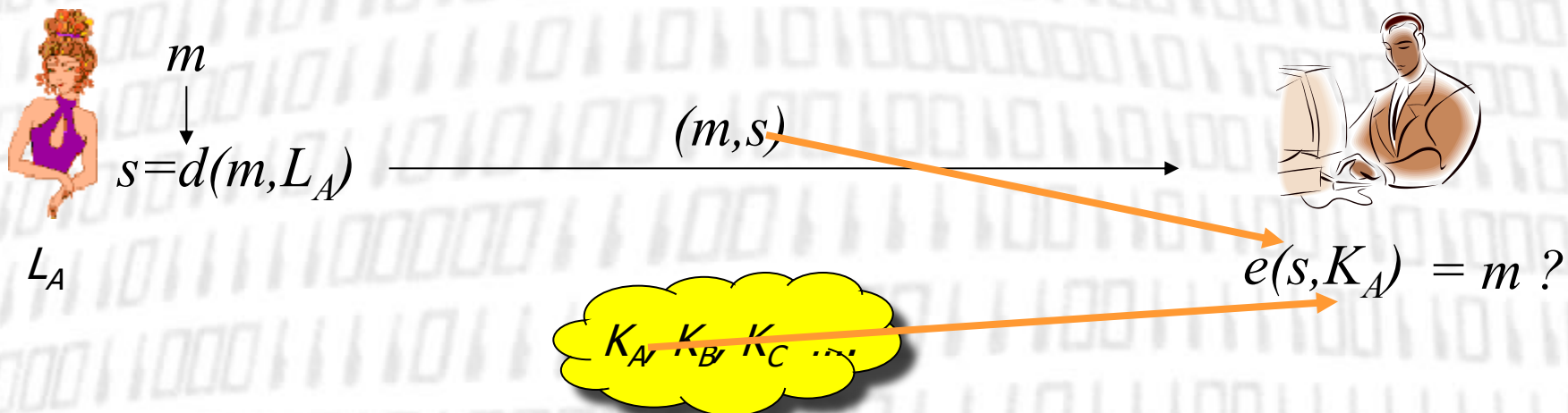
- Cassage total : l'attaquant retrouve la clé de signature.
- Falsification sélective (selective forgery) : pour un message m choisi par quelqu'un d'autre, l'attaquant est capable de déterminer avec une probabilité non négligeable la signature de ce message.
- Falsification existentielle (existential forgery) : l'attaquant est capable de créer un couple (m, s) valide.

Signature et systèmes asymétriques

➤ Tout système de chiffrement à clé publique satisfaisant

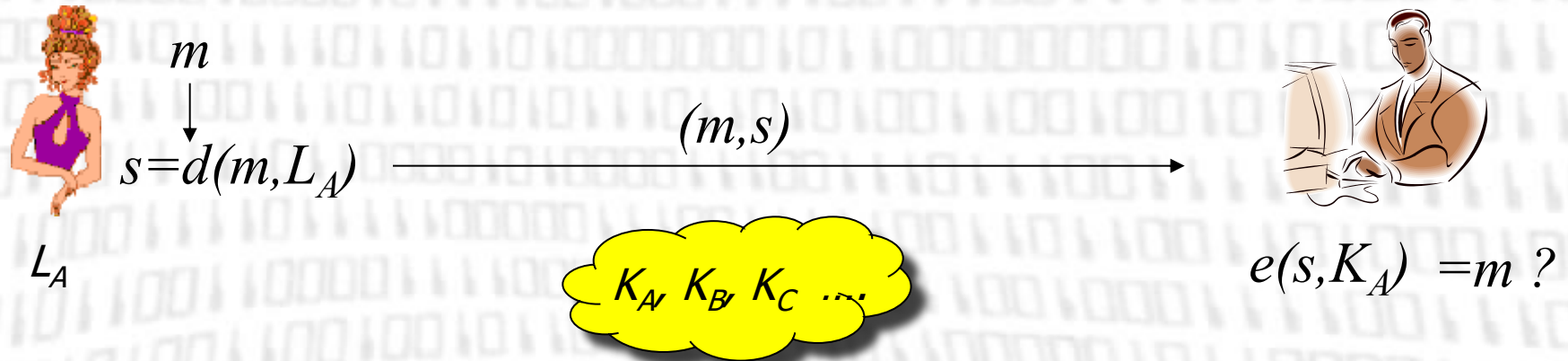
$$\mathcal{M} = \mathcal{C}, \quad \forall m \in \mathcal{M}, e(d(m, L), K) = m$$

peut être transformé en un schéma de signature

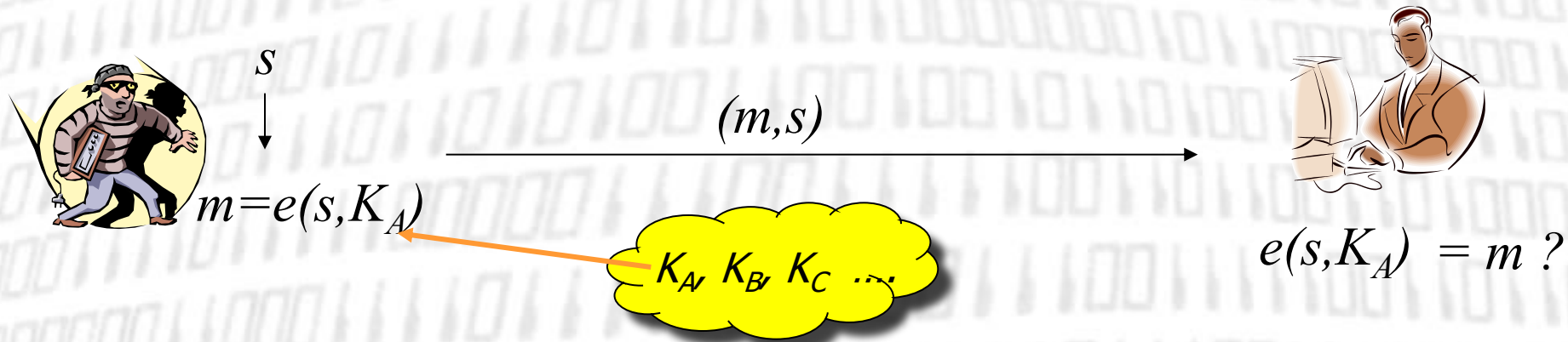


Le système RSA peut être utilisé pour élaborer un protocole de signature

Inconvénients



- Signer un message est aussi long qu'une opération de déchiffrement.
- La signature est aussi longue que le message à signer.
- La signature de message aléatoire est possible par un intrus.



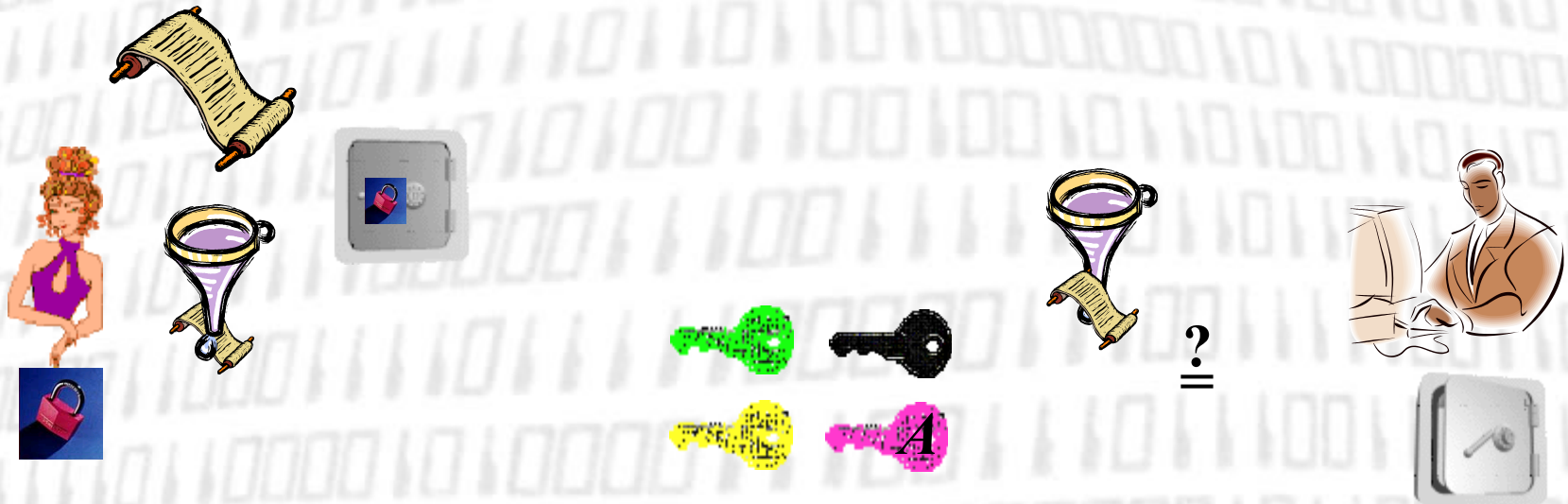
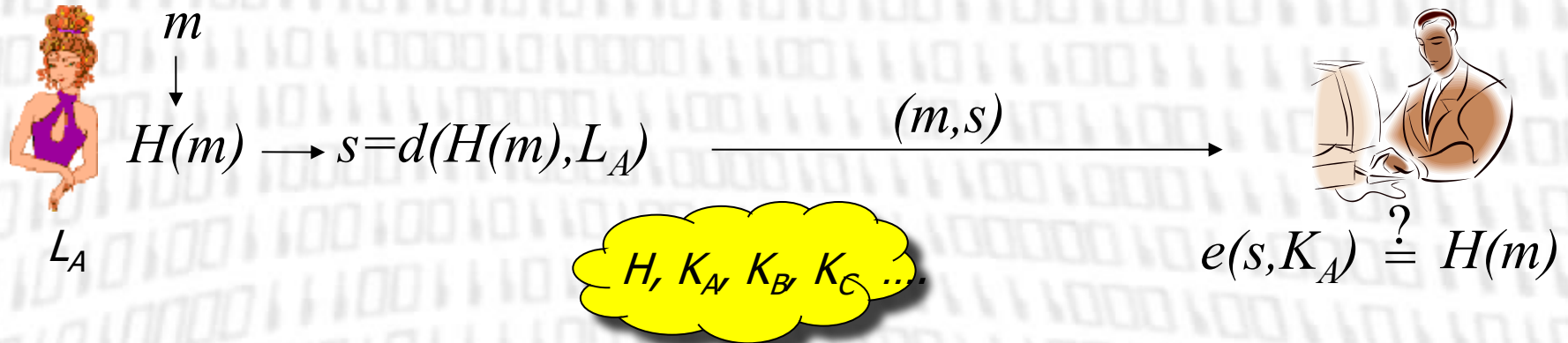
- L'utilisation d'une fonction de hachage permet de résoudre les problèmes précédents.

$$\begin{array}{lcl} H & : & \{0, 1\}^* \rightarrow \{0, 1\}^n \\ & & m \mapsto H(m) \end{array}$$

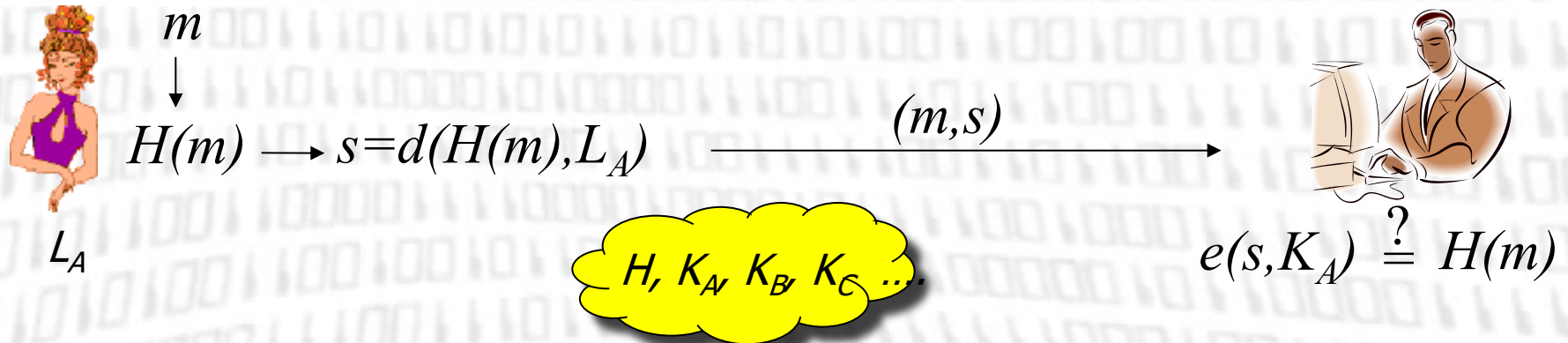


**compression
avec perte**

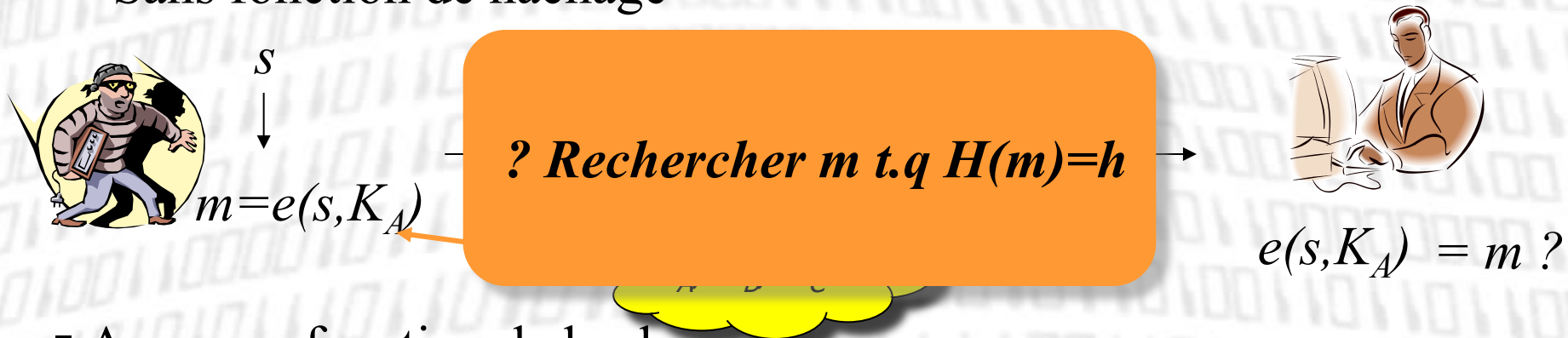
- L'utilisation d'une fonction de hachage permet de résoudre les problèmes précédents.



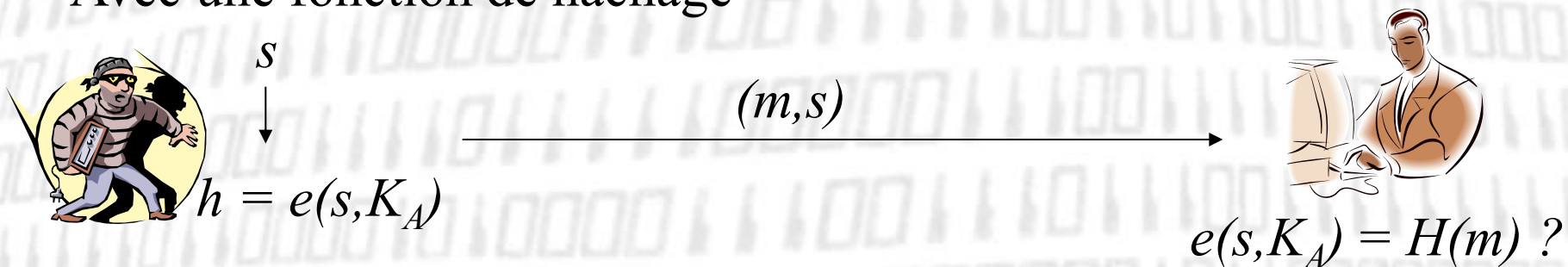
➤ Problématique pour le fraudeur



■ Sans fonction de hachage



■ Avec une fonction de hachage



DSA (Digital Signature Algorithm)

- Algorithme de signature adopté par le NIST en Mai 94 dans le cadre du DSS (Digital Signature Standard) du projet Capstone.
- Le DSS préconise trois algorithmes de signature : DSA, ECDSA, et RSA.
- Sécurité basée sur la problématique du logarithme discret.
- Modification du schéma de signature de ElGamal. Permet d'obtenir des signatures plus courtes.

➤ Public :

- p un nombre premier de taille t (multiple de 64 compris entre 512 et 1024).
- q un nombre premier de 160 bits qui divise $p-1$.
- $\alpha \in (\mathbb{Z}/p\mathbb{Z})^*$ une racine $q^{\text{ième}}$ de l'unité.
- $b = \alpha^a \text{ mod } p$
- H une fonction de hachage de $\{0,1\}^*$ dans $\{0,1\}^{160}$

➤ Secret : a ($1 \leq a \leq q-1$)

$$e_1 = H(m)\delta^{-1} \pmod{q}$$

$$e_2 = \gamma\delta^{-1} \pmod{q}$$



$$m \longrightarrow H(m)$$

$$\downarrow k, 1 \leq k \leq q-1$$

$$\gamma = (\alpha^k \pmod{p}) \pmod{q}$$

$$\delta = (H(m) + a\gamma)k^{-1} \pmod{q}$$

$$(m, \gamma, \delta)$$



$$\begin{aligned} \alpha^{e_1}\beta^{e_2} &= \alpha^{e_1+ae_2} \pmod{p} \\ &= \alpha^{(H(m)+a\gamma)\delta^{-1}} \pmod{q} \pmod{p} \\ &= \alpha^k \pmod{p} \end{aligned}$$

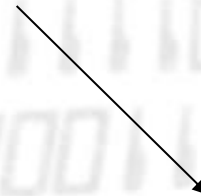
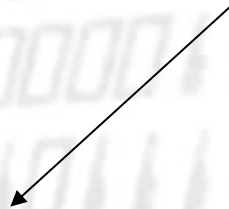
$$(\alpha^{e_1}\beta^{e_2} \pmod{p}) \pmod{q} = \gamma$$



- Taille des signatures : 320 bits
- Taille signatures RSA : 512 – 1024 – 2048 bits
- Taille signatures ElGamal : 1024 bits



- Procédé de sélection du DSA par le NIST non public
- Standard développé par la NSA
- Génération des signatures plus rapide que la vérification
- Avec un petit exposant public, la vérification des signatures est rapide avec le RSA



Une signature peut être vérifiée plusieurs fois, l'algo de vérification doit être rapide.

La signature est souvent utilisée dans les cartes à puces, l'algo de signature doit être rapide.

Canal subliminal

➤ Public :

- p un nombre premier de taille t (multiple de 64 compris entre 512 et 1024).
- q un nombre premier de 160 bits qui divise $p-1$.
- $\alpha \in (\mathbb{Z}_p, \times)$ une racine $q^{i\grave{e}me}$ de l'unité.
- $b = \alpha^a \text{ mod } p$
- H une fonction de hachage de $\{0,1\}^*$ dans $\{0,1\}^{160}$

➤ ~~Secret~~ : a ($1 \leq a \leq q-1$)



$$M \longrightarrow H(M)$$

$$\downarrow m, 1 \leq m \leq q-1 \text{ (message)}$$

$$\gamma = (\alpha^m \text{ (mod } p)) \text{ (mod } q)$$

$$\delta = (H(M) + a\gamma)m^{-1} \text{ (mod } q)$$

$$(M, \gamma, \delta)$$



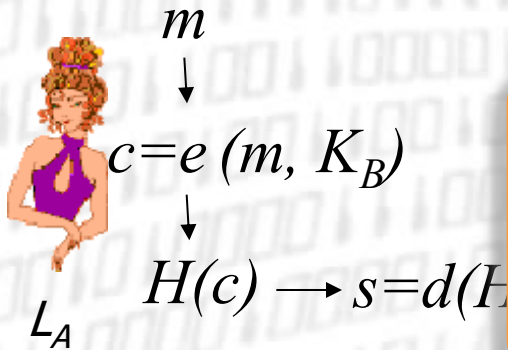
$$a \text{ (} 1 \leq a \leq q-1 \text{)}$$

$$m = (H(M) + a\gamma)\delta^{-1} \text{ (mod } q)$$

Chiffrement + Signature

Faut-il chiffrer puis signer ou signer puis chiffrer ?

➤ Chiffrement puis signature

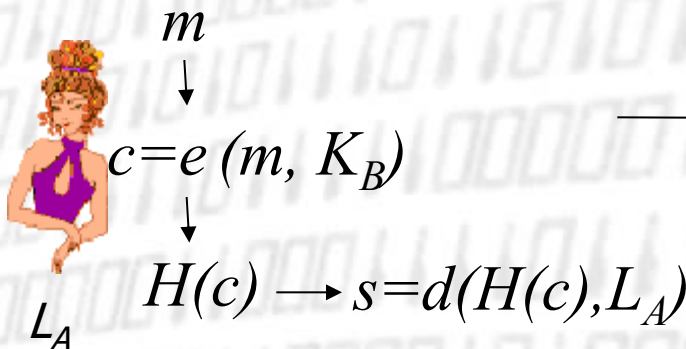


Permet à un intrus de signer des messages dont il n'est pas l'auteur.



$$e(s, K_A) = H(c) ?$$

$$m = d(c, L_B)$$



$((c, s'))$

$$s' = d(H(c), L_C)$$

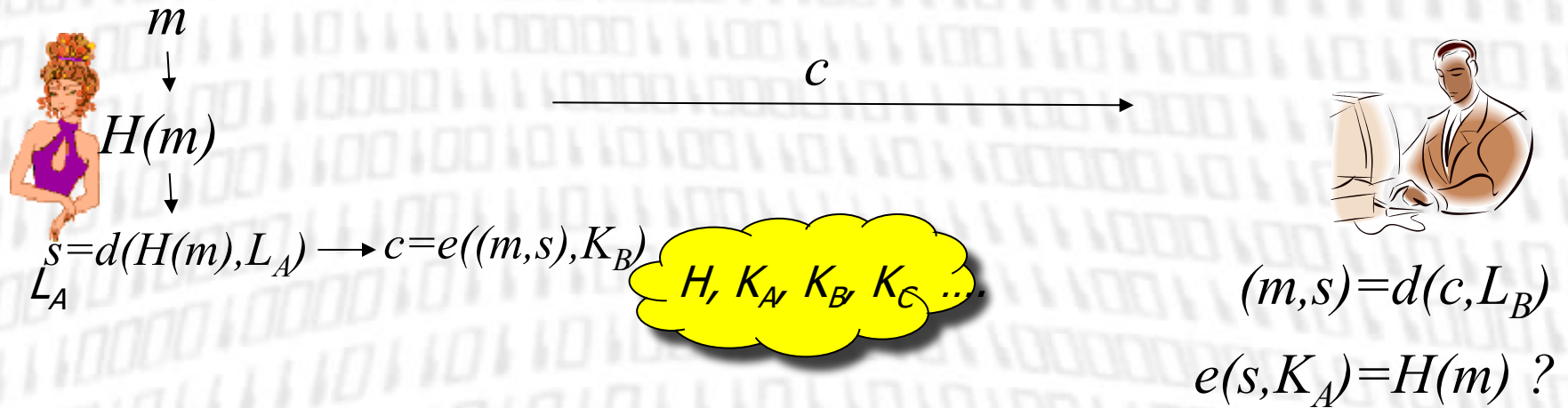


$$e(s, K_C) = H(c) ?$$

$$m = d(c, L_B)$$

Chiffrement + Signature

➤ Signature puis chiffrement



Généralement, déchiffrer un message est plus long que vérifier une signature. Selon le contexte ce procédé permet de mener une attaque de type DoS envers Bob.

La signature RSA en pratique

message de t bits

M

128-160 bits

$H(M)$

étape d'encodage

entier sur $\log_2(n)$ bits

$E(H(M))$

$\text{Sig}(\text{clé privée}, E(H(M)))$

2 standards :

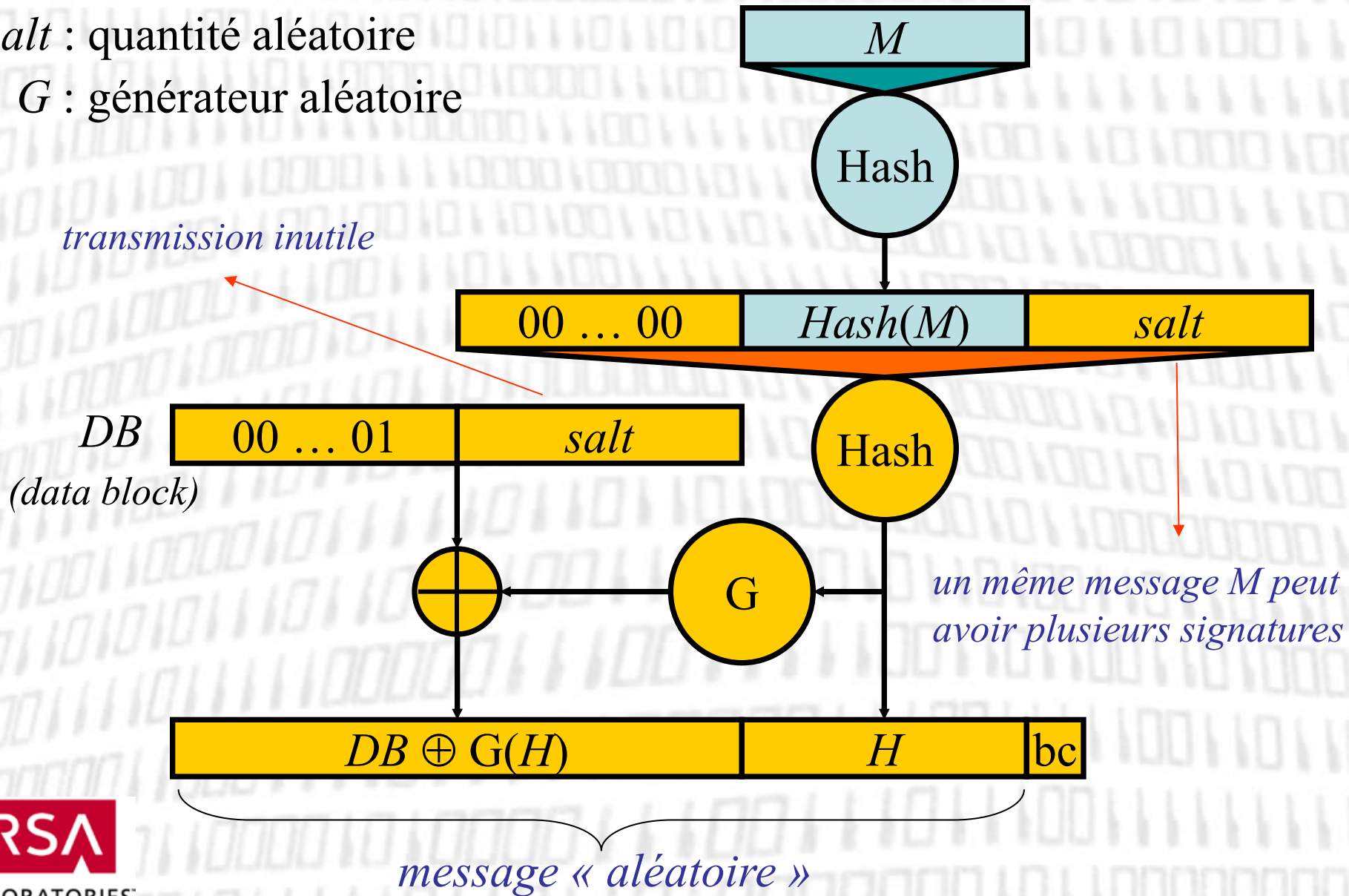
- PKCS #1 v1.5 (Nov. 1993)
- PKCS #1 v2.1 (Sep. 1999) : utilise la méthode PSS

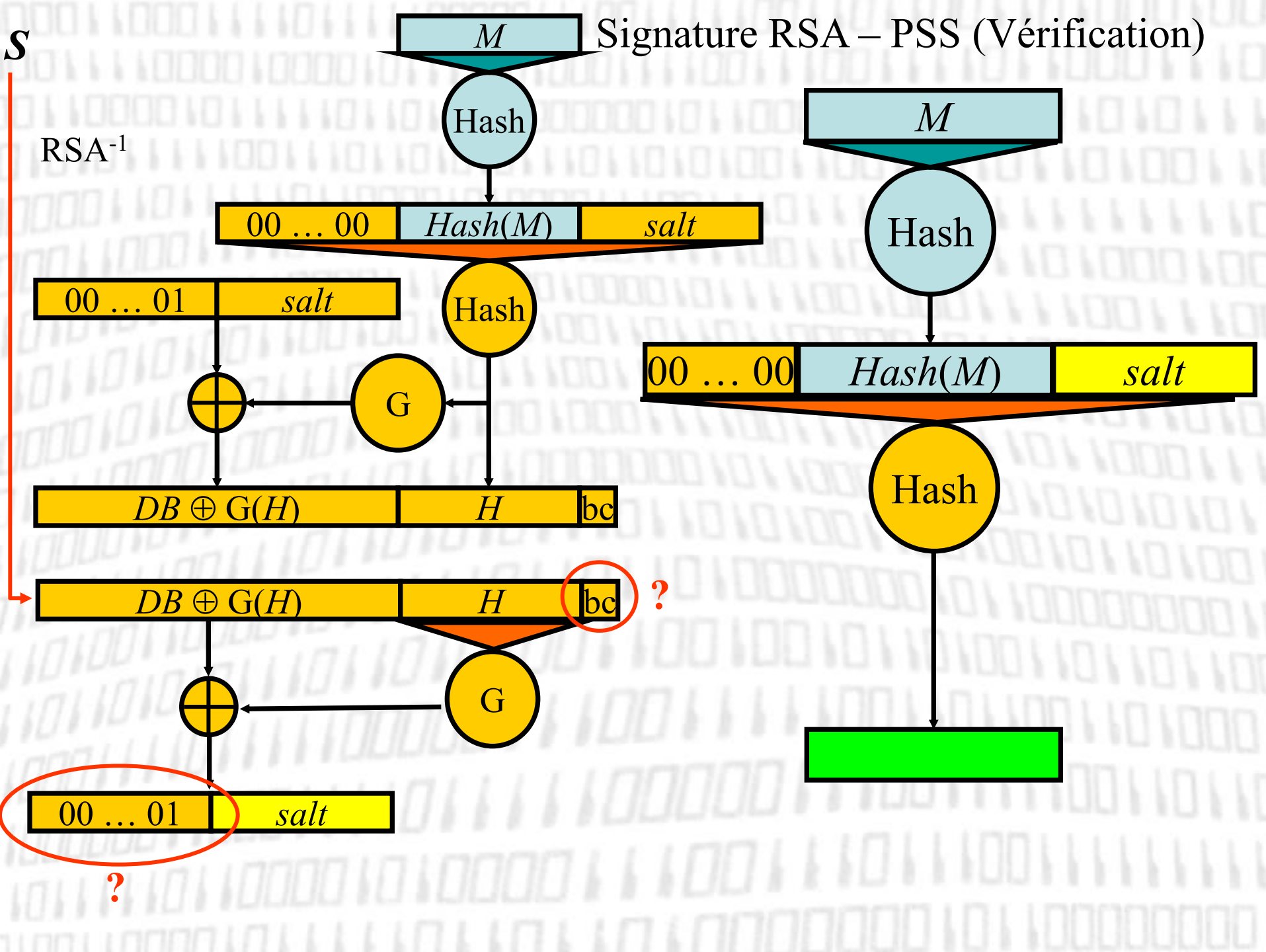
PSS : Probabilistic Signature Scheme (M. Bellare et P. Rogaway, Eurocrypt 1996)

Signature RSA - PSS

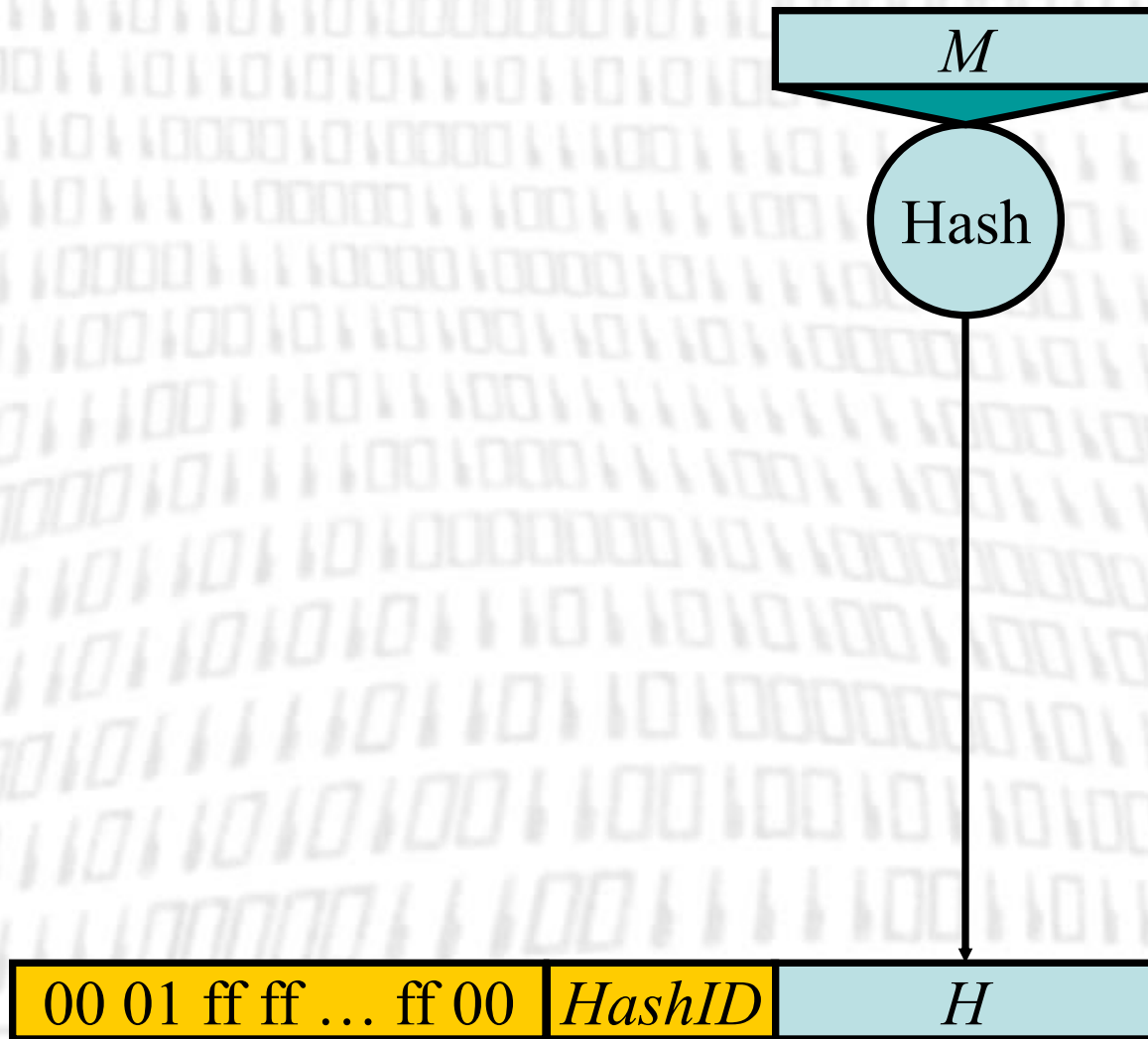
salt : quantité aléatoire

G : générateur aléatoire





Signature PKCS #1 v1.5



➤ Inverser RSA $\Rightarrow$ Possibilité de fabriquer des signatures au format PKCS #1 v1.5



➤ Inverser RSA $\Leftrightarrow$ Possibilité de fabriquer des signatures au format RSA PSS

Si un algorithme A est capable de fabriquer une signature valide au format RSA PSS, alors il existe un algorithme B utilisant A comme sous-routine capable d'inverser RSA en un temps « équivalent » au temps d'exécution de A .